

Informe Técnico de Evaluación de Seguridad – Frontend

Módulo de Administración Vulnerable

Introducción

Este informe presenta el análisis de seguridad del frontend desarrollado en Vue. Se evaluaron las vulnerabilidades en base a los cuatro casos establecidos en el enunciado del ejercicio, verificando su manifestación y nivel de exposición en el cliente.

Caso 1 – Entrada sin validación y salida sin escape (XSS)

Componente afectado: `UserSearch.vue`

Evaluación:

- El parámetro `query` se envía al backend sin validación ni sanitización.
- El backend responde sin escapar el contenido, lo cual expone a **XSS reflejado**.
- Vue mitiga parcialmente el riesgo al escapar automáticamente las interpolaciones (`{{ resultado }}`), pero:
 - El uso de `v-html` o la manipulación directa del DOM anula esta protección.
 - El backend continúa siendo el principal vector vulnerable.

Mitigación recomendada:

- Escapar la respuesta en el backend usando `html.escape()` o librerías como `bleach`.
- Evitar el uso de `v-html` salvo que el contenido sea completamente sanitizado.
- Implementar validación de entrada en ambos extremos.

Caso 2 – Exportación sin autenticación ni control de acceso

Componente afectado: `ExportButton.vue`

Evaluación:

- El botón "Exportar usuarios" permite el acceso libre al endpoint `/admin/users/export`.
- No se utiliza autenticación ni se valida el rol del usuario.
- Cualquier visitante puede descargar datos sensibles desde la interfaz.

Mitigación recomendada:

- Requerir autenticación mediante JWT o cookies de sesión.
- Validar roles con RBAC en el backend.
- Ocultar o deshabilitar el botón en el frontend si el usuario no posee privilegios.

Caso 3 – Uso de librerías potencialmente vulnerables

Observación técnica:

- No se identifican dependencias explícitas dentro del código compartido.
- El uso de `Vue` y otras librerías de terceros debe ser auditado a través del archivo `package.json`.

Mitigación recomendada:

Ejecutar auditorías periódicas con herramientas como:

`npm audit fix`

`snyk test`

-
- Mantener actualizadas todas las dependencias.
- Remover o reemplazar librerías abandonadas o no mantenidas.

Caso 4 – Falta de protección contra CSRF en eliminación de usuarios

Componente afectado: `UserList.vue`

Evaluación:

- La acción de eliminación de usuarios se realiza mediante una petición `POST` sin ningún tipo de token CSRF.
- No se verifica la cabecera `Origin` ni `Referer`.
- Un atacante podría forzar la ejecución del `fetch()` desde otro dominio, afectando a usuarios autenticados si se usan cookies.

Mitigación recomendada:

- Implementar verificación de tokens CSRF únicos por sesión.
- Validar las cabeceras `Origin` y `Referer` en el backend.
- Utilizar métodos HTTP correctos (`DELETE`) y reforzar la autenticación en acciones críticas.

Resumen de Evaluación

Caso	¿Aparece en el frontend?	Estado de seguridad
1	Sí (<code>UserSearch.vue</code>)	Parcialmente mitigado por Vue, pero el backend sigue vulnerable
2	Sí (<code>ExportButton.vue</code>)	 Totalmente inseguro (sin autenticación ni control de acceso)
3	Potencial (dependencias)	 Depende del <code>package.json</code> , requiere auditoría manual

- 4 Sí (`UserList.vue`)  Sin protección CSRF, explotable mediante scripts externos

Conclusión

El frontend evaluado constituye un entorno realista y valioso para la simulación de escenarios vulnerables en aplicaciones web. Combinado con el backend analizado previamente, permite replicar casos de ataques como:

- **Cross-Site Scripting (XSS)**
- **Exfiltración de datos por endpoints expuestos**
- **Ataques Cross-Site Request Forgery (CSRF)**
- **Falta de control de acceso y validación de rol**